BÁO CÁO KIỂM THỬ MIỀN GIÁ TRỊ VÀ PHÂN TÍCH GIÁ TRỊ BIÊN

TÍNH NĂNG FR-04: QUẢN LÝ HỒ SƠ CÁ NHÂN (POOL A)

- **Mã sinh viên:** 23120127
- **Họ và tên:** Dương Trọng Hòa
- **Hệ thống được kiểm thử (SUT):** EShop Platform (`http://localhost:5173` / Backend API `http://localhost:3000`)
- **Kỹ thuật áp dụng:** Domain Testing (Equivalence Partitioning - EP) & Boundary Value Analysis (3-Value BVA theo chuẩn ISTQB)
- **Thời gian thực hiện:** 2026-10-18

---

1. ĐẶC TẢ YÊU CẦU & PHÂN TÍCH BIẾN ĐẦU VÀO (SPECIFICATION ANALYSIS)

1.1 Trích xuất đặc tả FR-04 từ System Requirements Specification

> - Người dùng đã đăng nhập có thể cập nhật: **Họ Tên**, **Số điện thoại**, **Địa chỉ giao hàng mặc định**.
> - **Số điện thoại hợp lệ**: bắt đầu bằng số `0`, từ 10–11 chữ số.
> - Email không được phép thay đổi qua giao diện.
> - Người dùng chỉ có thể cập nhật hồ sơ của chính mình; không thể tự thay đổi thuộc tính `role`.
> - *Ràng buộc giao diện chung (FR-21, FR-22)*: Mỗi trang chỉ có 1 thẻ `<h1>`, thông báo lỗi hiển thị ở phía trên nút Submit, các trường bắt buộc có dấu `*`.

1.2 Điều kiện tiên quyết (Preconditions)

- Người dùng đã đăng nhập thành công vào hệ thống EShop với tài khoản hợp lệ: `test@eshop.com` / `Test1234!` (`id = 2`, `role = 'user'`).
- Token xác thực JWT được đính kèm hợp lệ trong Header `Authorization: Bearer <token>`.

1.3 Danh sách biến đầu vào và ràng buộc

Tên biến đầu vào	Kiểu dữ liệu	Miền giá trị hợp lệ (Valid Domain)	Ràng buộc kỹ thuật & Nghiệp vụ (Constraints)
`Họ Tên` **(name)**	String	Chuỗi ký tự khác rỗng, độ dài từ 1 đến 255 ký tự.	Bắt buộc (có dấu `*`). Không được để trống.
`Số điện thoại` **(phone)**	String (Numeric)	Chuỗi số bắt đầu bằng ký tự `'0'`, độ dài từ 10 đến 11 chữ số.	Bắt buộc (`*`). Định dạng chuẩn: `^0\d{9,10}$`. Không chứa chữ cái, khoảng trắng hay ký tự đặc biệt.
`Địa chỉ giao hàng` **(shipping_address)**	String	Chuỗi ký tự mô tả địa chỉ, độ dài từ 1 đến 255 ký tự.	Bắt buộc (`*`). Không được để trống.
`Email` *(Biến kiểm thử âm)*	Email String	Không có (Read-only trên UI).	**Cấm thay đổi**: UI khóa chỉnh sửa. API Backend phải bỏ qua hoặc từ chối nếu Client cố tình gửi kèm email mới.
`role` *(Biến kiểm thử bảo mật)*	String	Không có (Không nhận từ Client).	**Ràng buộc an ninh (SEC-06)**: Client cấm tự đổi quyền thành `'admin'`. Backend bắt buộc phải chặn hoặc phớt lờ.
`id` / `user_id` *(Biến kiểm thử IDOR)*	Integer	`id = 2` (Trùng ID giải mã từ Token).	Người dùng chỉ có quyền cập nhật hồ sơ của chính mình, cấm sửa sang ID của người khác (SEC-02).

2. PHÂN VÙNG TƯƠNG ĐƯƠNG (EQUIVALENCE PARTITIONING - EP)

Dựa trên các biến đầu vào, phân chia miền giá trị thành các lớp tương đương hợp lệ (Valid) và không hợp lệ (Invalid):

Biến	Lớp tương đương	Loại	Giá trị đại diện	Mô tả kiểm thử
`Họ Tên`	**EC1.1**	Valid	`"Nguyễn Văn A"`	Chuỗi họ tên thông thường hợp lệ (1–255 ký tự).
	EC1.2	Invalid	`""` (Rỗng)	Bỏ trống Họ Tên (0 ký tự).
	EC1.3	Invalid	`"A".repeat(256)`	Chuỗi vượt quá 255 ký tự (256 ký tự).
`Địa chỉ giao hàng`	**EC2.1**	Valid	`"123 Lê Lợi, Quận 1, TP.HCM"`	Chuỗi địa chỉ hợp lệ (1–255 ký tự).
	EC2.2	Invalid	`""` (Rỗng)	Bỏ trống Địa chỉ giao hàng (0 ký tự).
	EC2.3	Invalid	`"B".repeat(256)`	Chuỗi địa chỉ vượt quá 255 ký tự.
`Số điện thoại`	**EC3.1**	Valid	`"0912345678"`	Bắt đầu bằng số `0`, độ dài đúng **10 chữ số**.
	EC3.2	Valid	`"01234567890"`	Bắt đầu bằng số `0`, độ dài đúng **11 chữ số**.

Biến	Lớp tương đương	Loại	Giá trị đại diện	Mô tả kiểm thử
	EC3.3	Invalid	`""` (Rỗng)	Bỏ trống Số điện thoại.
	EC3.4	Invalid	`"091234567"`	Bắt đầu bằng `0`, nhưng độ dài **< 10 chữ số** (9 số).
	EC3.5	Invalid	`"012345678901"`	Bắt đầu bằng `0`, nhưng độ dài **> 11 chữ số** (12 số).
	EC3.6	Invalid	`"1912345678"`	Đủ 10 số nhưng **không bắt đầu bằng số** `0` (bắt đầu bằng 1-9).
	EC3.7	Invalid	`"091234567a"`	Chứa ký tự chữ cái hoặc ký tự đặc biệt.
`Email`	**EC4.1**	Valid	*(Read-only / Giữ nguyên)*	Email không bị can thiệp trên UI.
	EC4.2	Invalid	`"hacker_moi@eshop.com"`	Cố tình truyền `email` mới trong body request API.
`role`	**EC5.1**	Valid	*(Không gửi trong body)*	Không truyền thuộc tính `role`.
	EC5.2	Invalid	`"role": "admin"`	Cố tình truyền `role: "admin"` để nâng quyền (SEC-06).
`Target User ID`	**EC6.1**	Valid	`id = 2`	Thao tác trên đúng hồ sơ của mình.
	EC6.2	Invalid	`id = 1`	Cố tình gửi request sửa hồ sơ của user khác (IDOR).

3. PHÂN TÍCH GIÁ TRỊ BIÊN (BOUNDARY VALUE ANALYSIS - 3-VALUE BVA)

Áp dụng kỹ thuật 3-Value BVA theo chuẩn ISTQB ($Min-1, Min, Min+1, Nominal, Max-1, Max, Max+1$):

3.1 Bảng phân tích giá trị biên 3 giá trị

Biến kiểm thử	Ranh giới (Boundary)	Min - 1	Min	Min + 1	Nominal	Max - 1	Max	Max + 1
`Số điện thoại` *(Độ dài số)*	$[10, 11]$ chữ số	`9 số` *(Invalid)*	`10 số` *(Valid)*	`11 số` *(Valid - Max)*	`10 số`	`10 số` *(Min)*	`11 số` *(Valid)*	`12 số` *(Invalid)*
`Số điện thoại` *(Ký tự đầu - ASCII)*	Bắt đầu bằng `'0'` (ASCII 48)	ASCII 47 `'/'` *(Invalid)*	ASCII 48 `'0'` *(Valid)*	ASCII 49 `'1'` *(Invalid)*	`'0'`	*(Biên đơn điểm)*	ASCII 48 `'0'`	ASCII 49 `'1'`
`Họ Tên` *(Độ dài chuỗi)*	$[1, 255]$ ký tự	`0 ký tự` *(Invalid)*	`1 ký tự` *(Valid)*	`2 ký tự` *(Valid)*	`12 ký tự`	`254 ký tự` *(Valid)*	`255 ký tự` *(Valid)*	`256 ký tự` *(Invalid)*
`Địa chỉ` *(Độ dài chuỗi)*	$[1, 255]$ ký tự	`0 ký tự` *(Invalid)*	`1 ký tự` *(Valid)*	`2 ký tự` *(Valid)*	`25 ký tự`	`254 ký tự` *(Valid)*	`255 ký tự` *(Valid)*	`256 ký tự` *(Invalid)*

4. KẾT QUẢ THỰC THI KIỂM THỬ THỰC TẾ (TEST EXECUTION RESULTS)

Tất cả 16 kịch bản kiểm thử đã được thực thi trực tiếp trên hệ thống EShop thực tế (Frontend `http://localhost:5173`, Backend `http://localhost:3000`, CSDL `database.sqlite`). Hình ảnh bằng chứng đã được lưu trữ đầy đủ tại thư mục `screenshots/fr04/`.

Mã TC	Kịch bản kiểm thử	Dữ liệu đầu vào (Input)	Kết quả mong đợi (Expected Result)	Kết quả thực tế (Actual Result)	Trạng thái	Bằng chứng (Screenshot)	Mã lỗi (Bug ID)
EXE-01	Kiểm tra GUI, thẻ `<h1>` & Khóa trường Email	Quan sát giao diện; Console đếm `<h1>`	Đúng 1 thẻ `<h1>`; trường Email disabled; nhãn có `*` đỏ; nút Lưu màu xanh.	Đúng 1 thẻ h1. Trường Email có thuộc tính disabled, không cho phép nhập liệu. Nút Lưu màu xanh.	**PASS**	`EXE-01_GUI_Email_Check.png`	—
EXE-02	Cập nhật hợp lệ — SĐT 10 số (Biên Min)	Họ tên: `"Nguyễn Văn A"` SĐT: `"0912345678"` (10 số) Đ/c: `"123 Lê Lợi"`	Cập nhật thành công (HTTP 200). Lưu SĐT 10 số vào CSDL.	Hệ thống từ chối và hiển thị thông báo lỗi: "*Số điện thoại không hợp lệ. Vui lòng nhập 9-10 chữ số*".	**FAIL**	`EXE-02_Valid_10Digits_Phone.png`	**BUG-FR04-01**

Mã TC	Kịch bản kiểm thử	Dữ liệu đầu vào (Input)	Kết quả mong đợi (Expected Result)	Kết quả thực tế (Actual Result)	Trạng thái	Bằng chứng (Screenshot)	Mã lỗi (Bug ID)
EXE-03	Cập nhật hợp lệ — SĐT 11 số (Biên Max)	Họ tên: `"Trần Thị B"` SĐT: `"01234567890"` (11 số) Đ/c: `"456 Nguyễn Huệ"`	Cập nhật thành công (HTTP 200). Lưu SĐT 11 số vào CSDL.	Hệ thống từ chối và hiển thị thông báo lỗi: *"Số điện thoại không hợp lệ. Vui lòng nhập 9-10 chữ số"*.	**FAIL**	`EXE-03_Valid_11Digits_Phone.png`	**BUG-FR04-01**
EXE-04	Biên dưới Họ tên & Địa chỉ (Min = 1 ký tự)	Họ tên: `"A"` (1 char) SĐT: `"0912345678"` Đ/c: `"1"` (1 char)	Cập nhật thành công (HTTP 200).	Hệ thống chấp nhận độ dài tối thiểu 1 ký tự cho Họ Tên và Địa chỉ. Lưu thành công.	**PASS**	`EXE-04_BVA_Min_1Char.png`	—
EXE-05	Biên trên Họ tên & Địa chỉ (Max = 255 ký tự)	Họ tên: `"A".repeat(255)` Đ/c: `"B".repeat(255)`	Lưu thành công chuỗi 255 ký tự. Giao diện an toàn.	Hệ thống lưu thành công chuỗi 255 ký tự cho Họ Tên và Địa chỉ. Giao diện hiển thị an toàn, không bị tràn khung.	**PASS**	`EXE-05_BVA_Max_255Chars.png`	—
EXE-06	Để trống Họ tên (Min - 1 = 0 ký tự)	Họ tên: `""` SĐT: `"0912345678"` Đ/c: `"123 Lê Lợi"`	Từ chối cập nhật. Báo lỗi phía TRÊN nút bấm (FR-22).	Hệ thống chặn cập nhật khi để trống Họ tên. Thông báo lỗi hiển thị bằng tiếng Việt rõ ràng ở phía trên nút bấm theo đúng FR-22.	**PASS**	`EXE-06_Error_Empty_Name.png`	—
EXE-07	Để trống Địa chỉ (Min - 1 = 0 ký tự)	Họ tên: `"Nguyễn Văn A"` SĐT: `"0912345678"` Đ/c: `""`	Hệ thống từ chối và yêu cầu nhập địa chỉ bắt buộc.	Hệ thống cho phép lưu địa chỉ rỗng, hiển thị thông báo cập nhật thành công và ghi chuỗi rỗng vào CSDL.	**FAIL**	`EXE-07_Error_Empty_Address.png`	**BUG-FR04-02**
EXE-08	Họ tên & Địa chỉ vượt biên trên (Max + 1 = 256 ký tự)	Họ tên: `"A".repeat(256)` Đ/c: `"B".repeat(256)`	Chặn không cho nhập/lưu quá 255 ký tự.	Input cho phép nhập quá 255 ký tự. Hệ thống gửi request và trả về cập nhật thành công, không chặn giới hạn độ dài.	**FAIL**	`EXE-08_BVA_MaxPlus1_256Chars.png`	**BUG-FR04-03**
EXE-09	Bỏ trống Số điện thoại	SĐT: `""` (Rỗng)	Chặn và hiển thị lỗi SĐT bắt buộc.	Hệ thống hiển thị: *"Số điện thoại không hợp lệ. Vui lòng nhập đúng 9-10 chữ số"*. Chặn thành công.	**PASS**	`EXE-09_Error_Empty_Phone.png`	—
EXE-10	SĐT ngắn hơn quy định (Min - 1 = 9 chữ số)	SĐT: `"091234567"` (9 số)	Từ chối cập nhật vì SĐT phải từ 10–11 số.	Hệ thống từ chối cập nhật, hiển thị: *"Số điện thoại không hợp lệ. Vui lòng nhập đúng 9-10 chữ số"*.	**PASS**	`EXE-10_BVA_Phone_9Digits_Fail.png`	—
EXE-11	SĐT dài hơn quy định (Max + 1 = 12 chữ số)	SĐT: `"012345678901"` (12 số)	Từ chối cập nhật vì vượt quá 11 số.	Hệ thống từ chối cập nhật, hiển thị: *"Số điện thoại không hợp lệ. Vui lòng nhập đúng 9-10 chữ số"*.	**PASS**	`EXE-11_BVA_Phone_12Digits_Fail.png`	—
EXE-12	SĐT không	SĐT: `"1912345678"` (10 số, bắt đầu bằng `'1'`)	Từ chối cập nhật	Hệ thống chấp nhận số điện thoại không bắt đầu bằng số	**FAIL**	`EXE-12_BVA_Phone_NotStartWithZero.png`	**BUG-FR04-**

Mã TC	Kịch bản kiểm thử	Dữ liệu đầu vào (Input)	Kết quả mong đợi (Expected Result)	Kết quả thực tế (Actual Result)	Trạng thái	Bằng chứng (Screenshot)	Mã lỗi (Bug ID)
	bắt đầu bằng số 0 (Biên ASCII Min + 1)		vì vi phạm quy tắc bắt đầu bằng số `0`.	không. Hệ thống hiển thị Cập nhật thành công.			**04**
EXE-13	SĐT chứa chữ cái / ký tự đặc biệt	SĐT: `"091234567a"`	Từ chối cập nhật vì chứa ký tự không phải chữ số.	Hệ thống chặn cập nhật, hiển thị: *"Số điện thoại không hợp lệ. Vui lòng nhập đúng 9-10 chữ số"*.	**PASS**	`EXE-13_Error_Phone_With_Letters.png`	—
EXE-14	Cố tình can thiệp thay đổi Email qua API payload	Body gửi: `"email": "hacker_moi@eshop.com"`	Backend bỏ qua hoặc từ chối, CSDL giữ nguyên email gốc.	Backend bỏ qua trường email trong payload, CSDL SQLite vẫn giữ nguyên email gốc 'test@eshop.com'. Đạt chuẩn an toàn FR-04.	**PASS**	`EXE-14_Security_Tamper_Email.png`	—
EXE-15	Cố tình nâng quyền `role = "admin"` qua API	Body gửi: `"role": "admin"`	Backend cấm sửa `role` (HTTP 400/403). CSDL giữ `role = 'user'`.	Backend cập nhật trực tiếp `role = 'admin'` vào SQLite. Dùng tài khoản `test@eshop.com` đăng nhập được luôn vào Web Admin `http://localhost:5174/`!	**FAIL**	`EXE-15_Bug_Privilege_Escalation.png`	**BUG-FR04-05**
EXE-16	Cố tình sửa hồ sơ tài khoản Admin (IDOR)	Body gửi: `id = 1, name = "Hacker"`	Từ chối cập nhật hoặc chỉ sửa hồ sơ chính mình. Admin giữ nguyên.	Hệ thống chỉ cập nhật theo ID trong JWT Token (`id = 2`). Hồ sơ của Admin (`id = 1`) được bảo vệ an toàn.	**PASS**	`EXE-16_Security_IDOR_Check.png`	—

5. TỔNG HỢP CÁC LỖI PHÁT HIỆN (DEFECT SUMMARY)

Tổng số test cases thực thi: **16**

- **Passed:** 10/16 (62.5%)
- **Failed (Phát hiện lỗi):** 6/16 (37.5%)

Danh mục 5 lỗi phát hiện được:

1. **BUG-FR04-01 (High - Validation Logic Sai Lệch)**: Hệ thống chặn các số điện thoại 10 số và 11 số hợp lệ theo đặc tả, đưa ra thông báo sai lệch yêu cầu "9-10 chữ số".
2. **BUG-FR04-02 (Medium - Data Integrity)**: Hệ thống cho phép cập nhật và lưu Địa chỉ giao hàng rỗng vào CSDL.
3. **BUG-FR04-03 (Medium - Boundary Validation)**: Không kiểm soát giới hạn độ dài tối đa 255 ký tự trên giao diện và backend, cho phép lưu chuỗi 256 ký tự.
4. **BUG-FR04-04 (High - Boundary Validation)**: Hệ thống bỏ qua ràng buộc bắt đầu bằng số `0`, chấp nhận lưu các số điện thoại bắt đầu bằng chữ số khác (`1-9`).
5. **BUG-FR04-05 (Critical - Security / Privilege Escalation)**: Lỗ hổng Mass Assignment cho phép người dùng tự thăng quyền thành Admin thông qua payload API `PUT /api/users/me`, vi phạm nghiêm trọng đặc tả FR-04 và chuẩn an ninh SEC-06.